BELTTRACK MARTIAL ARTS MANAGEMENT OS

Multi-Tenant Session Isolation & Browser Cookie Jar Architecture

Standards: RFC 6265, Supabase SSR, Next.js App Router | Date: November 2026 | Ref: ARCH-AUTH-002

1. EXECUTIVE SUMMARY & PROBLEM STATEMENT

Observed Behavior: When a tester or user logs into BeltTrack as User A in Tab 1, and subsequently opens Tab 2

2. IN-DEPTH ROOT CAUSE ANALYSIS

A. Single-Origin Cookie Jar (RFC 6265 Standard)

Browsers maintain one cookie storage per origin (e.g. http://localhost:3000). Cookies are never partitioned per tab or

B. Supabase SSR Session Token Architecture

BeltTrack uses @supabase/ssr with session cookies (sb-<project>-auth-token). Each successful login updates this key with the latest

C. Client Cross-Tab Auth Synchronization

In src/context/auth-context.tsx, Supabase onAuthStateChange listens for SIGNED_IN events via BroadcastChannel & localStorage storage events. When Tab

D. PostgreSQL Multi-Tenant Protection (school_id)

BeltTrack strictly enforces tenant scoping. A user belongs to one active school tenant. Overwriting cookies ensures

3. VISUAL ARCHITECTURE & CROSS-TAB DATA FLOW

MULTI-TENANT BOUNDARIES & SECURITY IMPLICATIONS

4. SECURITY ASSESSMENT: WHY BLIND MULTI-SESSION IS DANGEROUS

[CRITICAL] Cross-Tenant State Pollution

If Tab 1 thinks it is Dojo A and Tab 2 is Dojo B, client React states sharing one cookie can send Dojo A mutations with Dojo B auth headers, failing foreign-key constra

[HIGH] Immutable Financial Ledger Corruption

BeltTrack ledger receipts are append-only (REC-[YEAR]-[DISCIPLINE]-[INCR]). An ambiguous session could attribute tuition receipts or reversal credits to the wrong s

[HIGH] Cross-Site Request Forgery (CSRF)

Single-cookie session cancellation protects users from CSRF where a hidden tab forces actions on an unintended background session. Session prioritization is intenti

5. ARCHITECTURAL SOLUTIONS & COMPARISON MATRIX

Solution Architecture			
1. Isolated Browser Profiles	Chrome/Edge Profile or Incognito	**Zero Code**	Highest (OS Level)
2. Interactive Role Switcher	In-app persona preview (top-nav)	**Zero (Built-in)**	Safe (Read Sandbox)
3. Multi-Tenant Subdomains	<slug>.belttrack.com (Host cookies)	**Moderate (DNS/Proxy)**	Highest (Strict Boundary)
4. Session-Indexed URL Routes	/u/0, /u/1 (Google Account Model)	**High (Auth Refactor)**	High (Token Partitioned)
5. Tab-Isolated sessionStorage	sessionStorage + Bearer token header	**Moderate (SSR Impact)**	Moderate (No HttpOnly)

KEY ARCHITECTURAL INSIGHT FOR BELTTRACK MVP

The browser cancelling the first login is NOT a bug; it is the default RFC 6265 cookie jar protection.

ACTIONABLE RECOMMENDATIONS & IMPLEMENTATION BLUEPRINT

Section 6: Workflows | Section 7: Future Subdomain Blueprint | Section 8: Quality Checklist

6. IMMEDIATE TESTING WORKFLOWS (ZERO CODE CHANGES REQUIRED)

Workflow A: Testing Owner vs Student via Incognito / Private Window

1. In Tab 1 (Standard Window): Sign in as Dojo Owner (e.g. Join Code LEMS-JUDO-2026).
2. In Tab 2 (Incognito / InPrivate Window): Press Ctrl+Shift+N (Chrome/Edge) or Ctrl+Shift+P (Firefox).
3. Navigate to http://localhost:3000 and sign in as Student or Coach.

Result: Both sessions run simultaneously side-by-side with 100% cookie isolation and zero state conflicts.

Workflow B: Dedicated Browser Profiles (Best for Daily Development)

1. Click your browser profile icon in top-right corner -> Select "Add Profile" -> Name it "BeltTrack Owner".
2. Create a second profile named "BeltTrack Student".
3. Both windows have independent cookie jars, persistent logins, and full developer tools inspection.

Workflow C: Built-in BeltTrack Interactive Role Preview

1. While logged out or in preview mode, use the TopNav segment selector (Owner vs Student/Guardian).
2. Instantly renders simulated attendance, progress, and curriculum records without creating multiple sessions.

7. PRODUCTION BLUEPRINT: MULTI-TENANT SUBDOMAIN ISOLATION

For production hosting, academies should be hosted on unique subdomains (e.g. lems.belttrack.com and kaizen.belttrack.com). Because browser cookies default to Host-Only scoping (omitted Domain attribute), sessions on lems.belttrack.com are completely isolated from kaizen.belttrack.com. An instructor can easily have both tabs open in standard windows with zero collisions.

```
// src/middleware.ts - Production Subdomain Extraction & Routing
```

8. ARCHITECTURAL QUALITY CHECKLIST

- [X] RFC 6265 Compliance: Shared cookie jar behavior documented and understood.
- [X] Supabase Broadcast Synchronization: Cross-tab refreshSession() event verified.
- [X] Zero Hardcoded Colors: All styles and layouts conform strictly to BeltTrack design tokens.
- [X] Database Scoping Invariant: PostgreSQL school_id tenant isolation remains fully intact.